

腾讯安全 | 云鼎实验室

锋刃无影 御见未来

腾讯安全沙龙第3期（成都站）



IFS

关于我

About me

洛熙，独立安全研究员，研究领域：AI应用与安全

- 《Ai迷思录: Ai应用与安全指南》《prompt越狱手册》《Hello Ai》作者
- 马斯克Grok操纵总统大选案揭秘者
- Claude与Open Ai连续两届全球红队测试通关者
- Ai安全知识库(M-Wiki) 与社区创办人，灵溯LLM安全测试平台核心开发
- 米斯特Ai安全组核心成员，H3C芯云学院特邀讲师，某部特聘授课讲师，达摩院Ai训练师，活跃在各大知名Ai社区一线频道，参与国内外多家头部Ai厂商模型自检安全测试与安全培训，识别并捕获多起跨国Ai黑产攻击



议题：Ai赋能红队的技术实践与效能突破

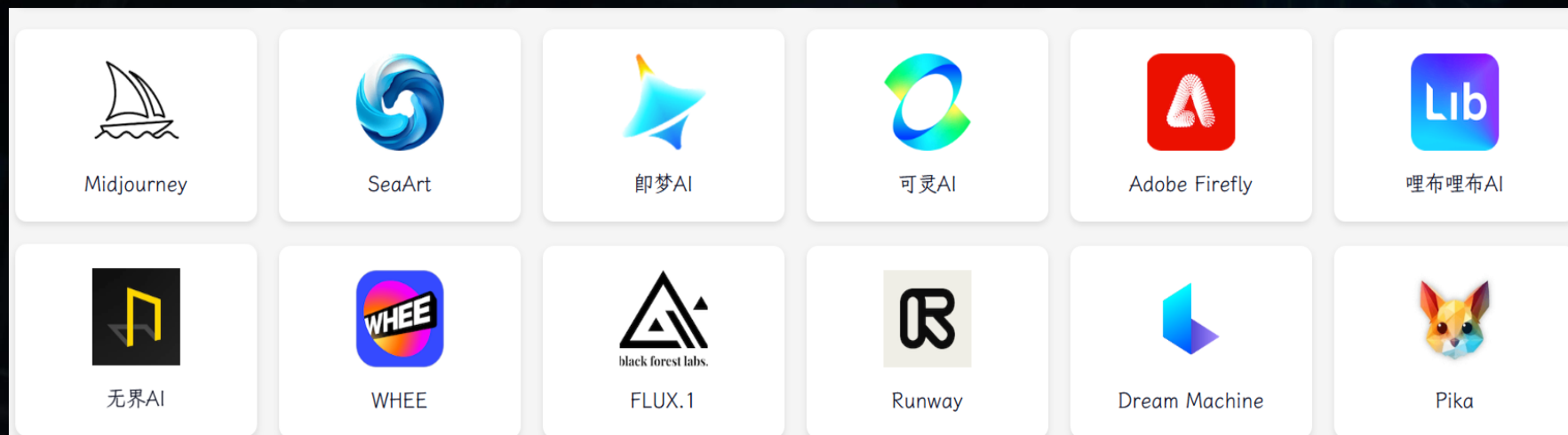
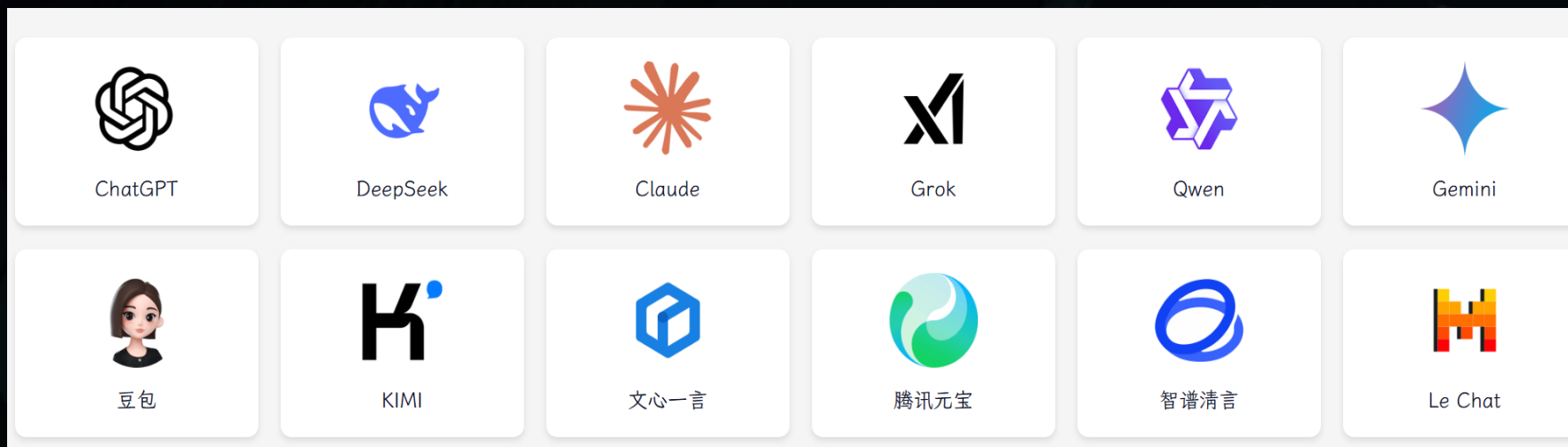
目录:

- 1: 模型工程实践中的那些坑点
- 2: 聚焦工程本质—Ai赋能武器化的实践
- 3: 模型既产品既Agent的原生赋能场景
- 4: Ai大模型热潮下自我反共识观点

1：模型工程实践中的那些坑点

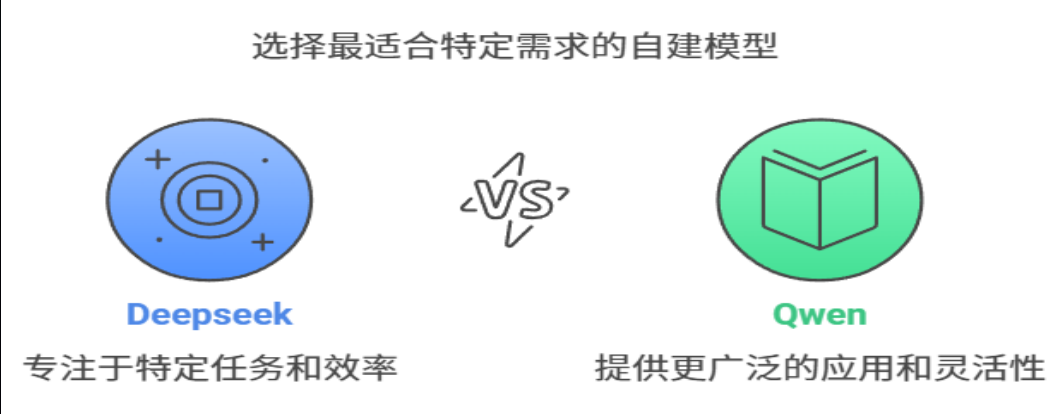
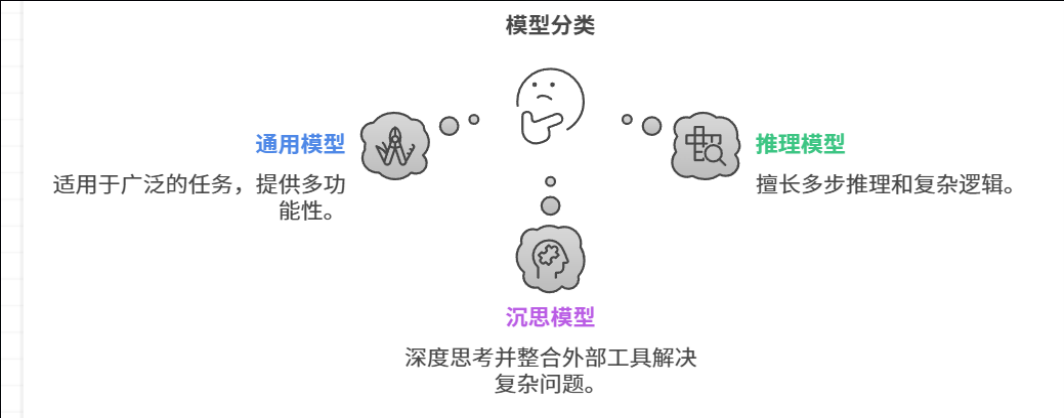
千模大战，那么多模型，我该选择谁？

选择困难症，好难选



无本不成真——熟悉模型特性与任务匹配度

根据任务确定模型分类——阅读官方文档——查看第三方测评基准——上手实践
(不要迷信官方自检的测评基础，模型刷榜已是潜规则)



自我测评表	
通用与推理模型	
	模型/服务
通用	Chatgpt4.1, Grok3 (不选择Think版本)> Gemini2.0Flash > Chatgpt4.5 (适合国外), deepseekV3 (适合国内)
推理	Claude3.7Max/Gemini2.5 Pro > ChatGP G3/o4mini > Grok3 Think > qwen2.5max > deep seekR1

沉思模型（各有千秋）	
模型	特点
Claude	擅长任务梳理
Chatgpt版本	范围最广，数据源偏欧美
谷歌版本	结合谷歌搜索和工具，适合谷歌生态
Grok版本	结合推特数据源和互联网资料爬取
智谱与通义版本	适合国内数据源

关于温度/采样/令牌/内容风控策略/联网搜索

- 1.根据任务分配合适的令牌长度不然会造成过多的资源消耗或任务强制中断
- 2.温度与采样的控制决定模型的稳定与创意程度，低区间趋于稳定（推荐），反则创意

输出长度

令牌数量

短 中 长

影响计算量

采样控制

温度

Top-K

Top-P

LLM 预测下一个令牌可能是什么的概率，然后对这些令牌概率进行采样，以确定将生成的下一个令牌。

自检模型风控排名(除开自建):

国外: Claude >Open Ai >Gemini>Grok

国内: QWEN>Z>deep seek



信息搜集小技巧

1.使用英文提问，模型会趋向于回复英文的信息源，并且指定优质信息源渠道和正反案例

2.如果模型有个性设置或记忆空间 可以填写：我是一名语言爱好者，最近在学习中文，所以与你与我的对话需要用中文交流，但你对资料信息源的搜索必须是英文来源，因为我看不懂中文版本的资料，我只是在学习他们的日常交流（可以有效降低杂乱的资料 and 避免模型风控）如Openai与Cluade 在面对除英文以外语言时会提升风控策略

3. AI 仍容易产生幻觉,记得验证思考的思维链，及每个模型存在数据截止时间，超出时间范围内的任务需要指明

背景信息:

我是一名专注于AI大模型安全的安全研究人员。我需要了解该领域在2025年3月出现的重大安全动向、新兴威胁、关键研究进展或值得关注的讨论。

我的目标是获取对我的研究工作有价值的前瞻性信息

期望目的:

请识别并总结在2025年3月时间，AI大模型安全领域发生或显现的、值得安全研究人员关注的重要事件、趋势、潜在漏洞或关键研究成果。请提供准确、可靠且具有前瞻性的洞察。

约束条件:

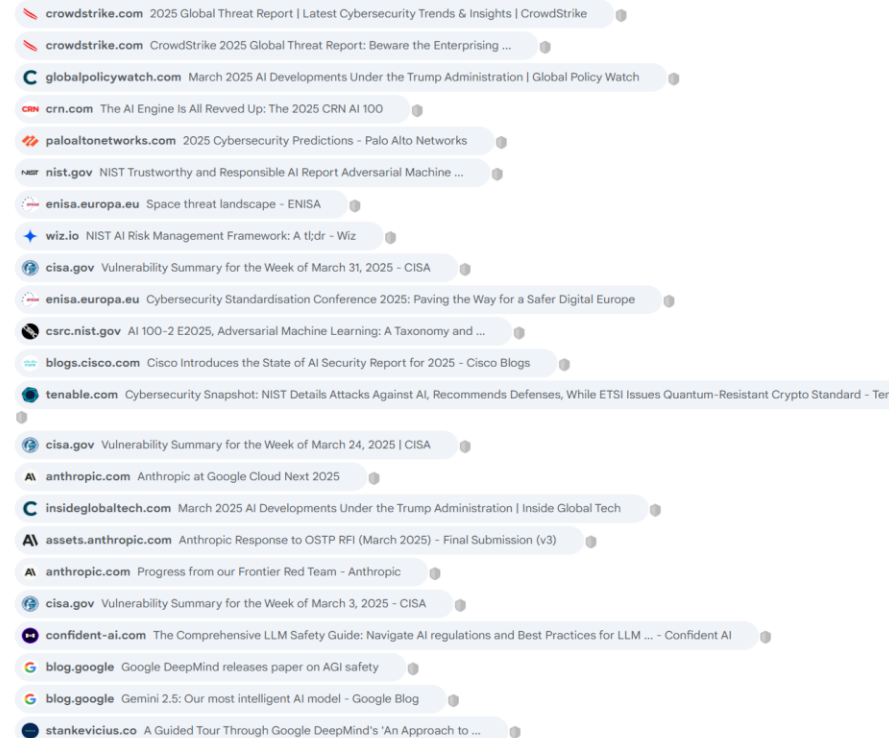
- 信息时效性: 聚焦于与2025年3月相关的预期发展和趋势（承认无法预测具体未来事件）。
- 主题范围: 严格限定在AI大模型安全。
- 信息来源语言: 仅限英文资料
- 来源可靠性 (核心要求):

- 优先采信: 官方机构报告 (如NIST, CISA)、顶级安全会议论文、知名研究机构/厂商的分析、同行评审期刊、CVE等。

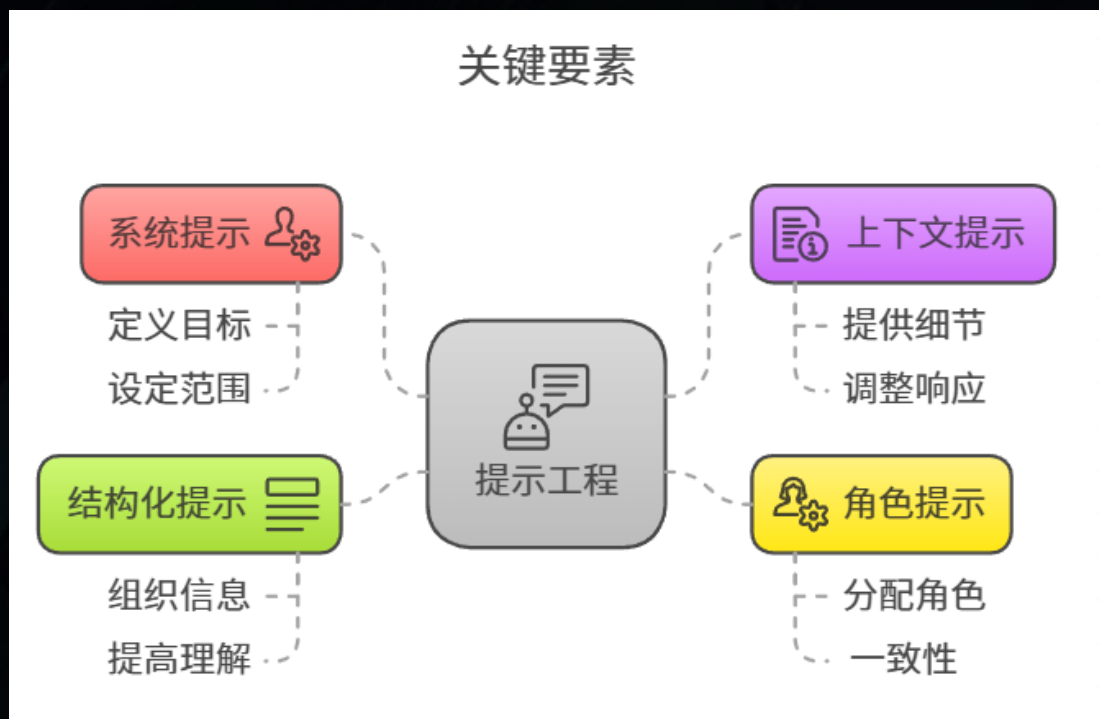
- 审慎使用 (需验证/标注): 来自X, Reddit, Medium, LinkedIn, Discord, YouTube, ResearchGate等平台的信息，仅当来源可信（如知名专家/机构账号）或可交叉验证时采纳，并明确标注来源和可靠性。

- 绝对避免/标记不可信: 匿名爆料、未经证实的个人博客、传闻、声誉不佳的来源。必须明确指出信息未经证实。

- 输出简洁: 结果需精炼，突出对安全研究人员最重要的信息点



Prompt 设计四要素



网络安全流量分析任务

身份/目标 (系统 & 角色): 你是一名SOC分析师, 需基于证据分析网络流量, 识别风险并提供行动建议

背景 (上下文):

内部服务器 10.1.1.50 (Web) 与外部可疑IP 198.51.100.X 持续通信 (TCP/443, 小包高频)

IDS告警: "Potential C2 Beaconing" (中置信度)

服务器近期无计划内变更

分析要求 (结构化需求):

评估风险级别及原因

列出关键可疑指标 (IoC/IoA)。

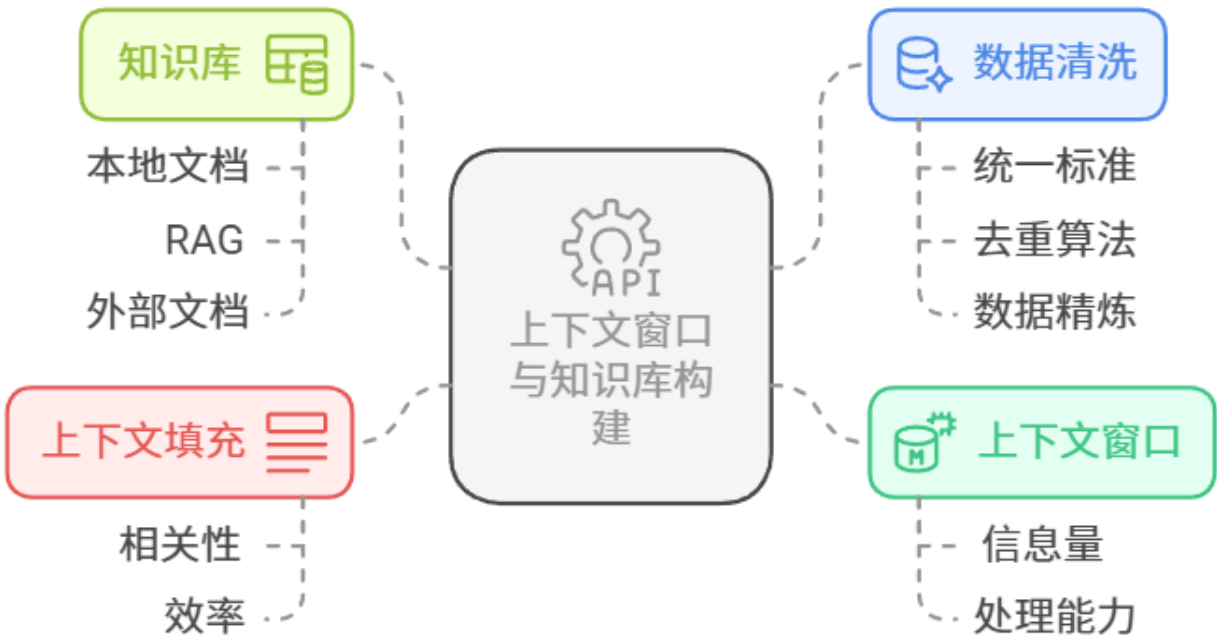
提出1-2个流量性质假设

建议后续调查步骤

上下文窗口与知识库构建

- 1.模型的上下文窗口是有限的，无论是构建怎么样的知识库，数据清洗皆为重中之重
- 2.上下文填充需要与任务最相关的信息，才能确保模型窗能获取最优质信息

上下文窗口与知识库构建



(同一起来源 未经精炼的低质量数据) 冗余 难聚合

```
# Tool A Report Snippet
Host: 10.1.1.5, Port: 8080, Severity: 9.8, Vuln: Apache Log4j RCE

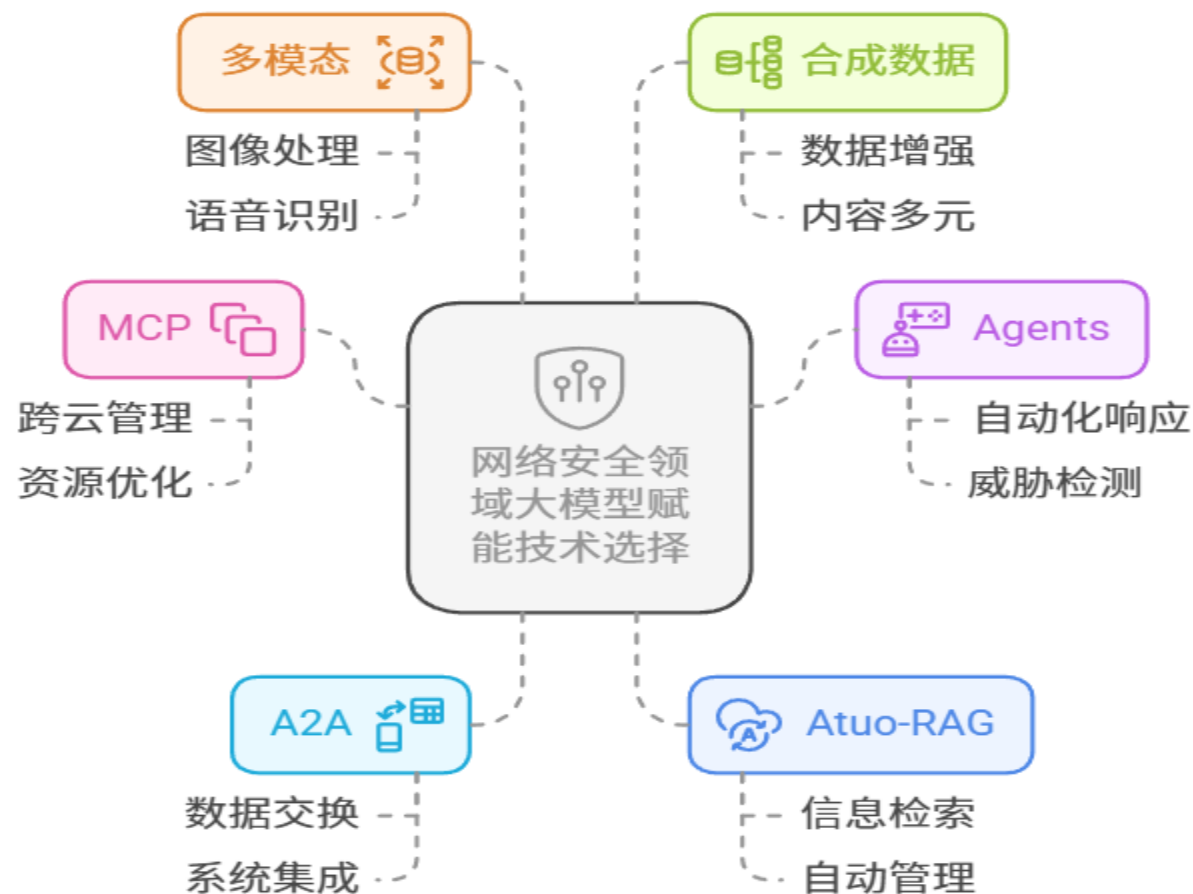
# Tool B Report Snippet
IP: 10.1.1.5, Service: http-alt, Risk: Critical, Finding: CVE-2021-44228 Log4Shell
```

(同一起来源 经过精炼的优质数据) 规范标准化

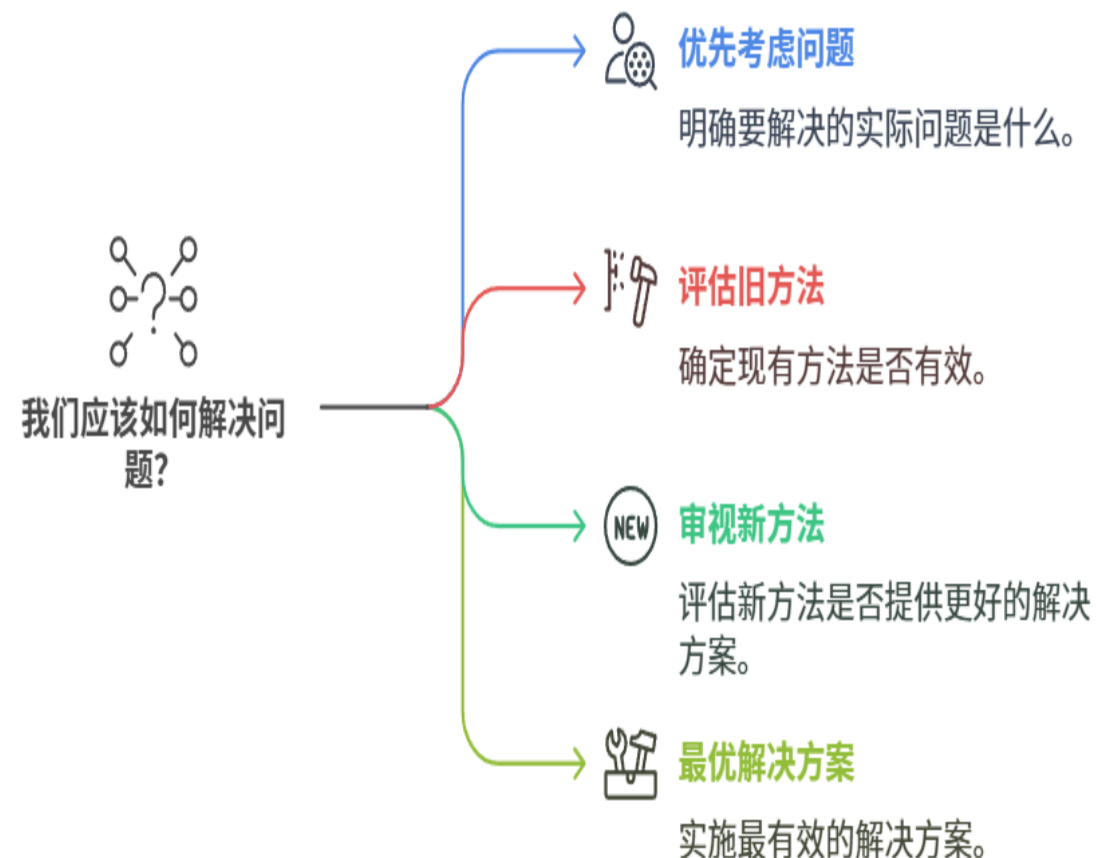
```
{
  "finding_uuid": "f8a3b-log4j-asset5", // 唯一 ID
  "asset_ip": "10.1.1.5", // 标准化资产标识
  "vulnerability_cve": "CVE-2021-44228", // 标准化漏洞标识
  "vulnerability_name": "Apache Log4j Remote Code Execution (Log4Shell)", // 标准化名称
  "severity": "Critical", // 标准化严重性
  "port": 8080, // 标准化端口
  "status": "Open", // 跟踪状态
  "sources": ["Tool A", "Tool B"], // 聚合来源
  "last_seen": "2025-4-1T11:00:00Z" // 精炼信息
}
```

AI每天每月每年多新技术？我该怎么选？

网络安全领域大模型赋能技术选择



回归本质，问题驱动，看钉子造锤子，而非盲目追随热点



对于AI技术自我反共识的认知思考

Ai领域百分之九十都是工程创新，而非新技术

把手弄脏 大胆进行设计创新的工程实践尝试，AI才能更好赋能自己

为什么这样说？

那些痛的回忆~

2022年 AI +Sora的 “预言之路”



痛在哪里

- 1.2022的模型技术不成熟，无法做到很好的智能规划与分析-----直到后来有了大模型~
- 2.安全工具 Soar Ai 三方都需要手搓API调度，工程量繁重复杂-----直到后来有了MCP~

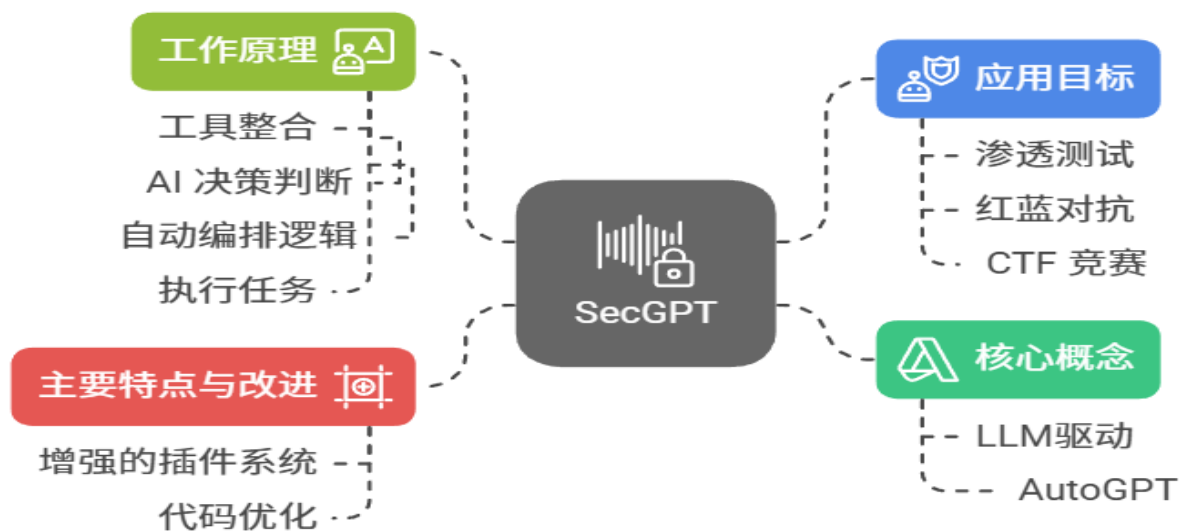
得到反思

- 1.先预判模型下一步能力是什么，如果你有想法，先落地，那怕做个垃圾出来
- 2.根据预判 在这之前把模型之外的应用做好，等着模型进化，纯AI应用没有护城河，脏活累活才是护城河

那些痛的回忆~

2023年 Ai LLM +Au To+ Agents 的 “先驱之路” -Sec GPT

SecGPT: 基于 LLM 的网络安全自动化助手



痛在哪里

1. 复杂多变的实时环境Ai覆盖率不足以全自动化判断

2. Ai得排列组合去尝试工具调用，导致性能与上下文的爆炸，最终演变成自动化编排工具

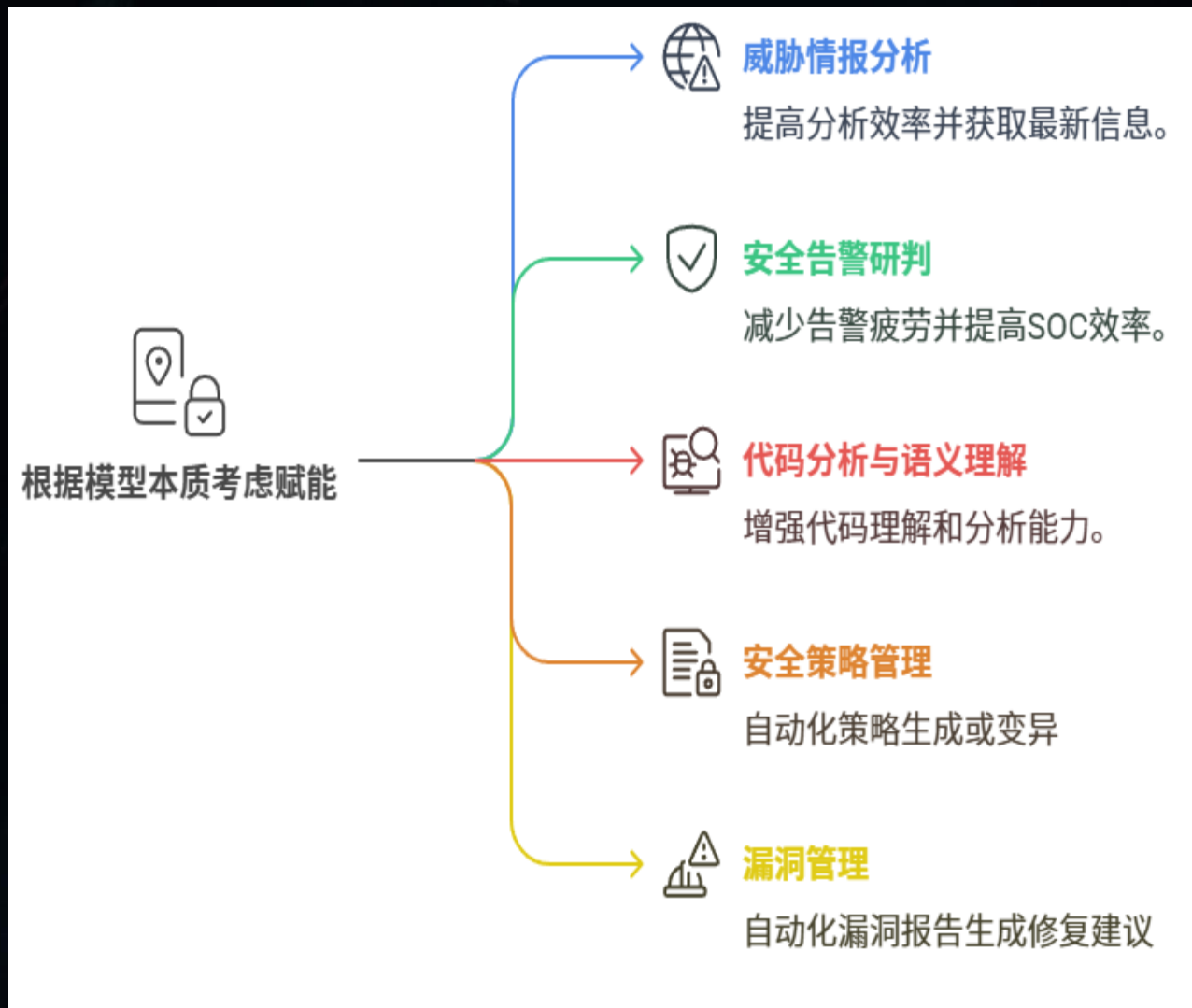
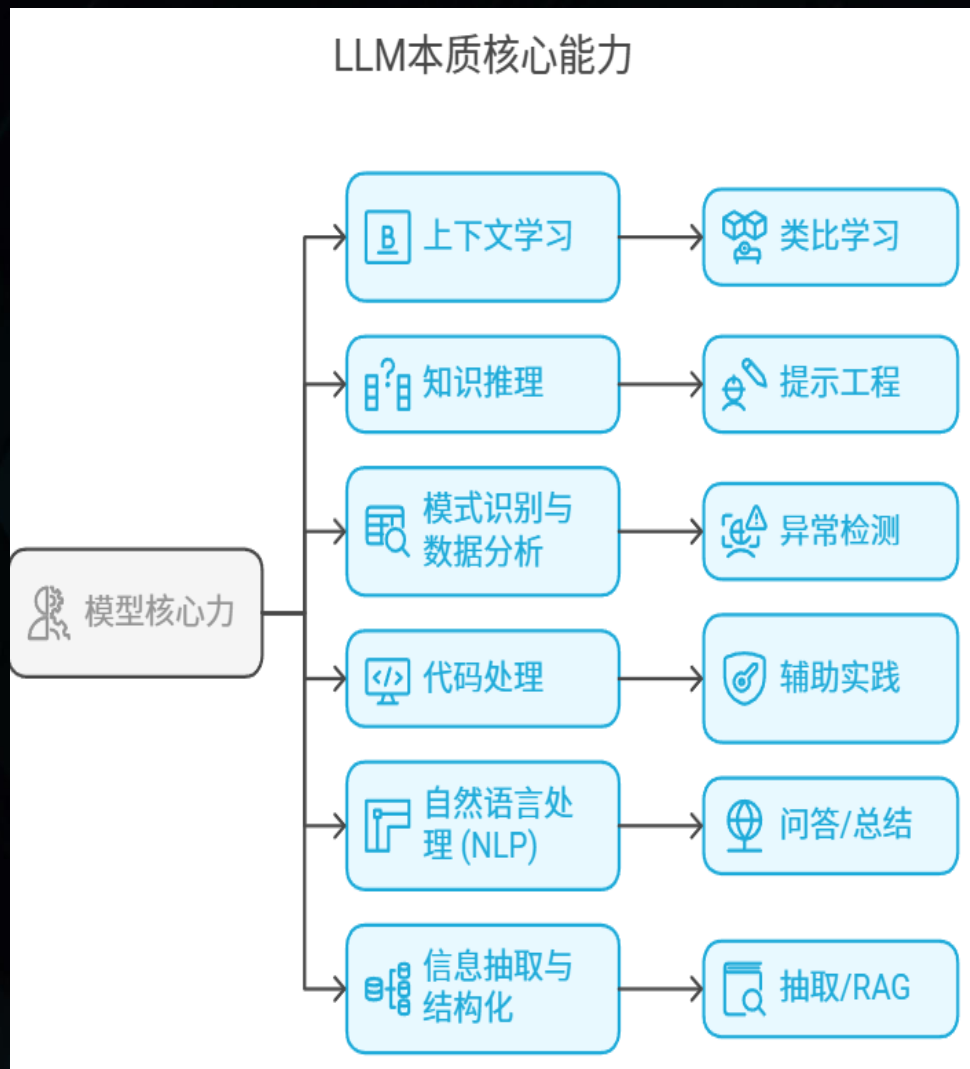
得到反思

不是什么都需要AI+，传统已高度自动化的系统，引入AI反而带来不可控的变量

引入得考虑 为什么一定要AI？采用AI的思路是什么？解决传统环境那种不足？投入产出比如何？

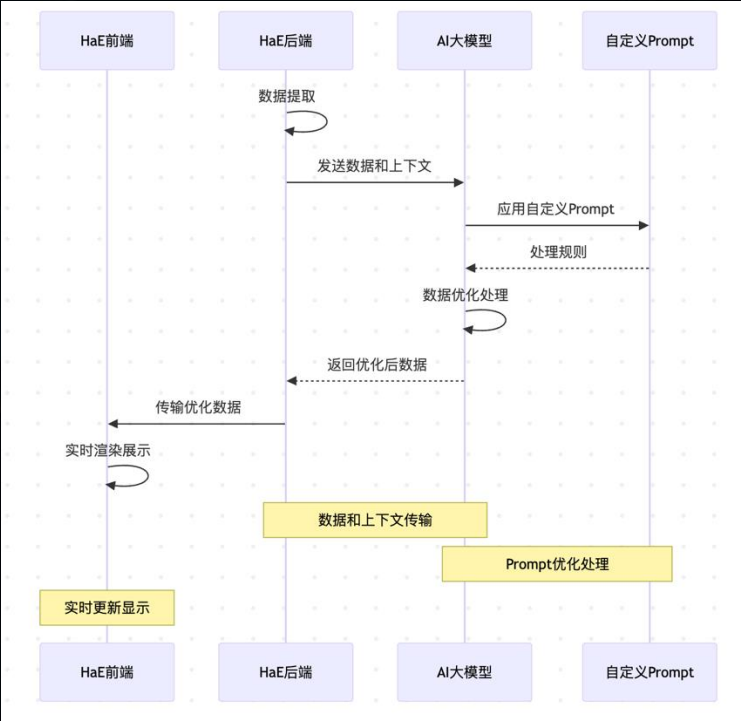
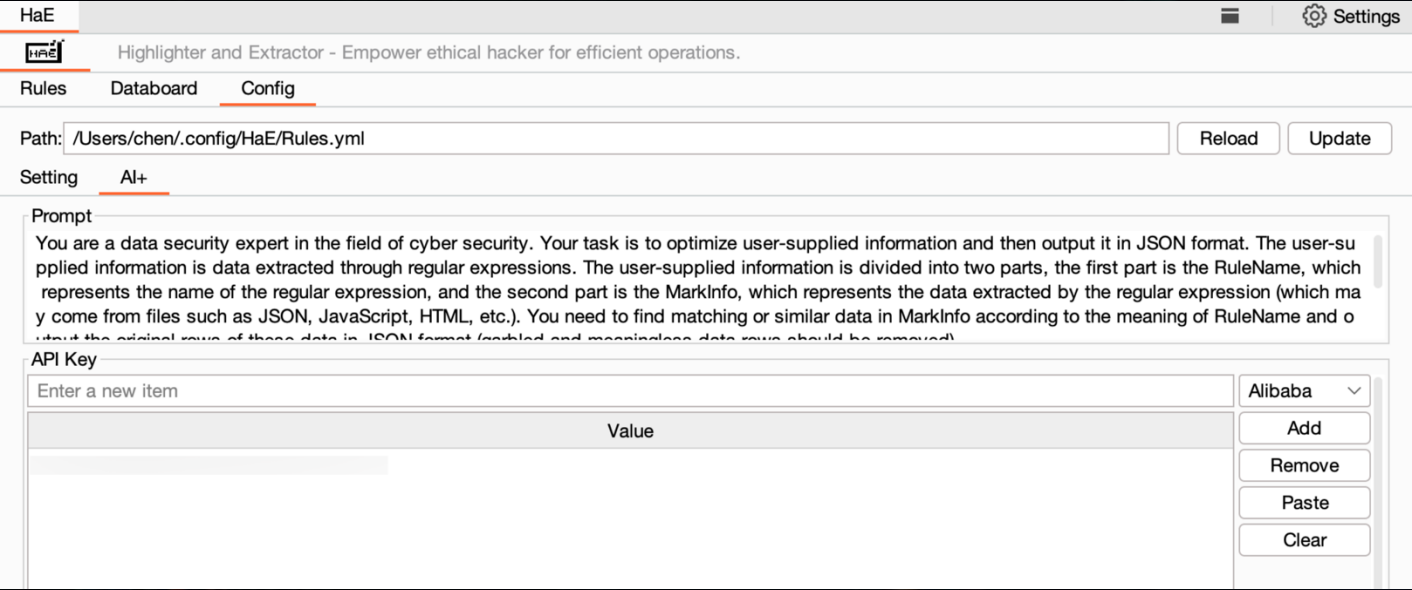
2：聚焦工程本质—Ai赋能武器化的实践

那么模型本质能力是什么？ 适合那些场景落地？



武器化赋能场景（一）HaE

传统规则匹配后+自定义需要的Ai规则+Ai二次语义分析处理=高质量敏感数据
且项目模块化设计，支持随时调用最新大模型



AI赋能逻辑：为了全面提升HaE工具的效能，我们设计了AI+模块，支持自定义Prompt功能和云端大模型API的调用能力。这一升级使得HaE在初次处理数据的基础上，能够进行二次深度识别与智能优化。通过将HaE规则所匹配的数据和数据关联的上下文信息交给AI大模型二次进行降噪、优化和提纯等操作，有效提高敏感数据发现准确率。

武器化赋能场景（一）HaE

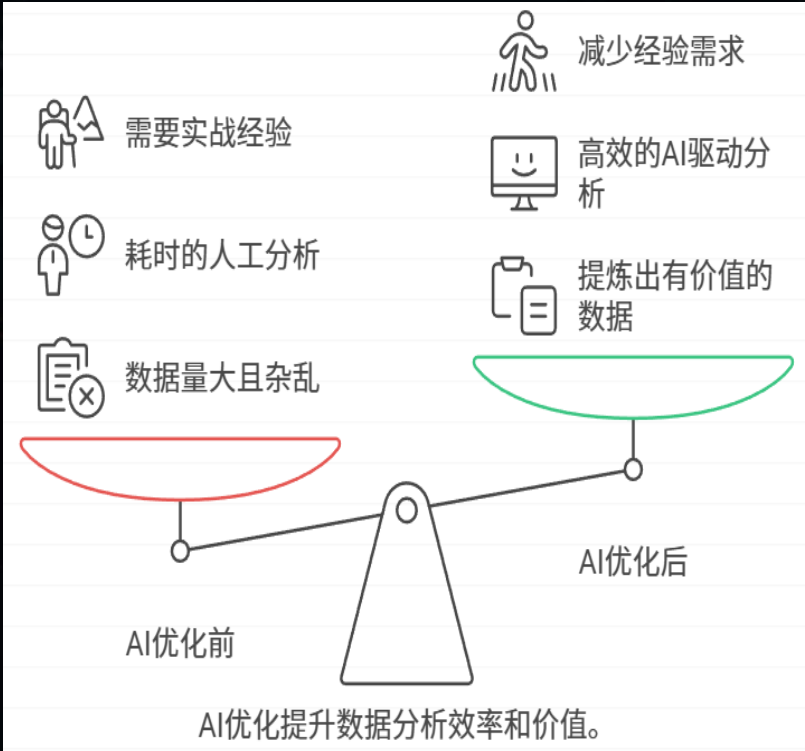
#	Information
1	*passinput: 'passinput_1VzwO'
2	*passTitle: 'pass-title_9l-b_'
3	*passwarn: 'passwarn_1whNP'
4	passinput: 'passinput_1VzwO'
5	SCORE_NOT_PASS: "当前设备不支持播放"
6	*passWrapper: 'passWrapper_2wyEw'
7	bioc_pass_success: "b19354a01b"
8	passwd: "*****"
9	pwd: "){0};return r&i?{usernameFragment:r.substr(12),passwo...
10	*passak: "M7bcdh2k6uqtYV5miaRil8m8x6LlaONq"
11	passWrapper: 'passWrapper_2wyEw'
12	passTitle: 'pass-title_9l-b_'
13	DEBUG_PASS: "**
14	accSetPwd_tangram: "/passApi/js/accSetPwd_tangram_cc6e...
15	*passinput: 'passinput_1VzwOc'
16	*passwd: 'passwd_ZOXyd'
17	*passWarn: 'passWarn_25BKE'
18	*passinput: 'passinput_1VzwOa'
19	passwd: 'passwd_ZOXyd'
20	*passconf: "http://passport.baidu.com/ubrwsbas"
21	*passWrap: 'passWrap_3fUNm'
22	*password: "text"
23	passText: "请输入6位数字密码"
24	passwarn: 'passwarn_1whNP'

AI优化前

#	Information
1	passinput: 'passinput_1VzwO'
2	passwd: "*****"
3	passak: 'M7bcdh2k6uqtYV5miaRil8m8x6LlaONq'
4	DEBUG_PASS: 'test8888'

AI+ Info
AI+ has completed the AI empowered work.
确定

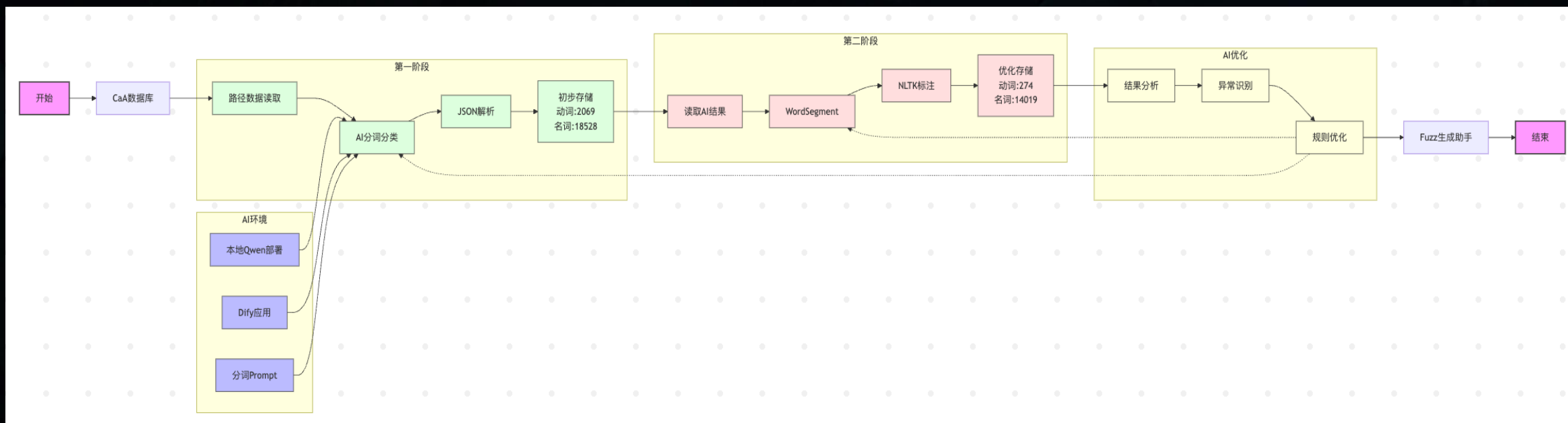
AI优化后



武器化赋能场景（二）CaA

简介： CaA 是漏洞挖掘领域辅助项目，主要用于分析拆解 HTTP 协议报文，提取其中参数,路径,文件,参数值等信息并统计频次，助力用户构建实战型 Fuzzing 字典，还能生成各类 HTTP 请求供 BurpSuite Intruder 进行 Fuzzing 工作。

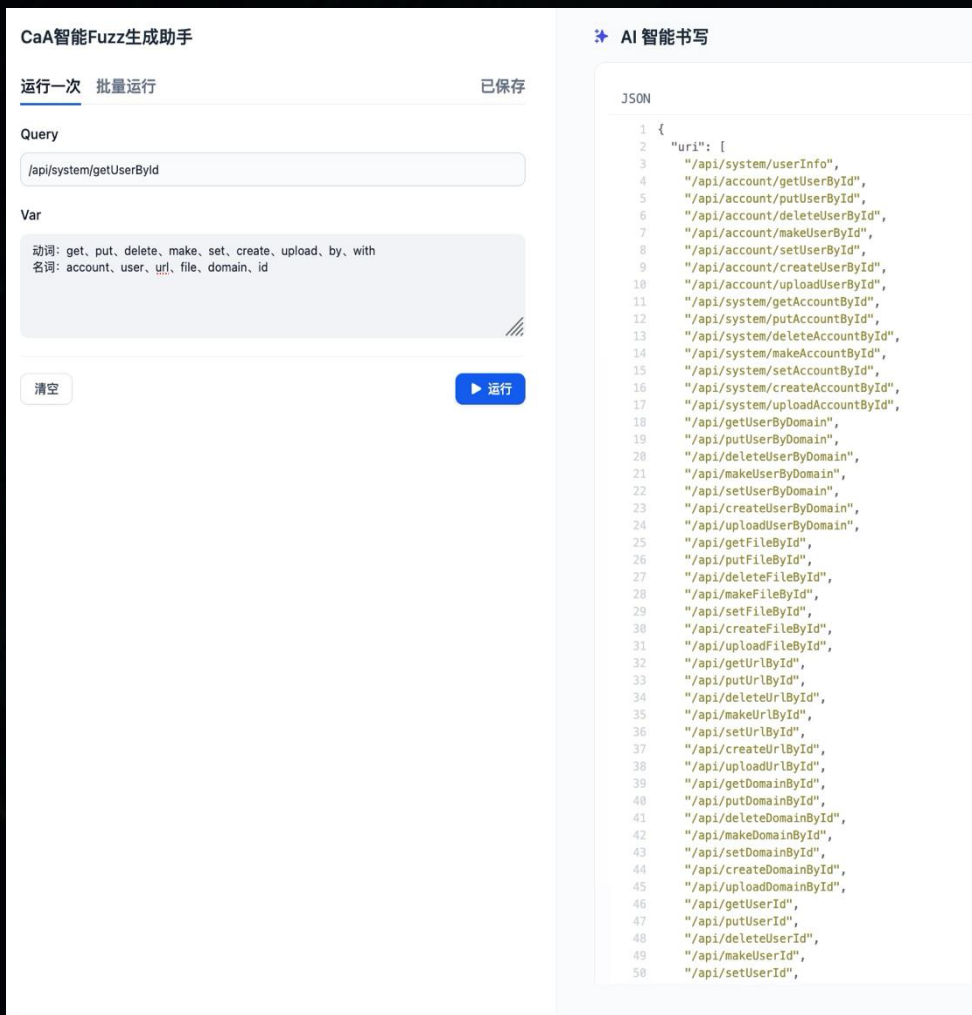
赋能逻辑： 原始数据经AI分类转为结构化词汇，让工具过滤构建Fuzz基础字典，AI二次接入优化规则=Fuzz助手



通过本地部署的Qwen 2.5 Coder大模型和Dify工作流编排对CaA数据库中4万条API路径进行分词处理，先由AI进行初步分类得到2069个动词和18528个名词，再使用NLTK和WordSegment进行二次处理优化为274个动词和14019个名词，最终基于这些数据构建了一个"Fuzz生成助手"用于Web Fuzzing测试路径的智能生成。

Ai CaA的实战场景

全自动化场景：基于构建的字典，结合目标测试模板的API逻辑，让Ai进行自动化Fuzz变异预测去生成针对性的payload



半自动化场景：基于Ai已预测构建的字典,人工进行结构的精准拆解，再基于拆解的结构回到自动化场景，让Ai进行Fuzz的二次变异 形成闭环 提高Fuzz覆盖率

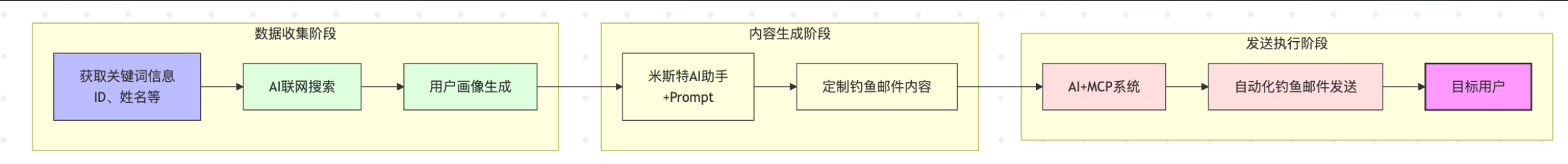
原API: /api/v1/getUserInfo
拆解:
/api/v1/ -> API前缀及版本
/getUserInfo -> 小驼峰命名格式: 动词+名词+名词

Fuzzing Payload预测逻辑:
/api/v1/\$动词字典载入口\$首字母大写(\$名词字典载入口\$)首字母大写(\$名词字典载入口\$)

Results		Positions
Capture filter: Capturing all items		
View filter: Showing all items		
Request	Payload	Status code ^
78	achievement	200
111	activities	200
243	agreement	200
2439	committee	200
2556	conference	200
4318	expert	200
4782	flow	200
6791	jobs	200
6798	journal	200
Request	Response	
Pretty	Raw	Hex
Render	CollectInfo	

武器化赋能场景（三） MCP与模型驱动的自动化钓鱼

基于实战获取的关键词信息（如ID、姓名），利用AI联网搜索技术绘制详细的用户画像。随后，结合米斯特AI助手+Prompt定义规则，根据用户画像生成高度定制化的钓鱼邮件内容。最后，通过AI+MCP平台实现钓鱼邮件的自动化发送，从而完成从信息收集到精准攻击的全流程闭环操作。



钓鱼演练场景：

- 1. 高级管理层目标演练（钓鲸行动）：** 针对企业高级管理层的定制化攻击模拟，旨在检测并提升关键决策层的安全意识与防范能力。此类演练通常采用高度个性化的诱饵信息，模仿来自可信来源的紧急请求或重要通知，以检验高管们对潜在威胁的敏感度和响应机制
- 2. 广泛覆盖员工群体的演练（撒网行动）：** 面向全体员工的大规模钓鱼邮件模拟测试，目的是评估整体组织内部的安全文化水平及普通职员对于常见网络钓鱼手法的识别能力。通过发送多样化的钓鱼邮件模板，涵盖从简单的链接点击诱导到复杂的凭证窃取尝试，以此来全面衡量各层级人员的信息安全素养，并据此制定针对性培训计划。

武器化赋能场景（三）MCP与模型驱动的自动化钓鱼

基于关键词获取用户画像



基于用户画像生成定制邮件

邮件内容

主题：北京网络安全大会2025：诚邀您作为演讲嘉宾

尊敬的EvilChen先生，

您好！

我是北京网络安全大会2025的组织委员会成员。我们一直密切关注着您的研究成果和在网络安全领域的贡献，特别是您在GitHub上分享的HaE工具（高亮和提取工具）以及对OverSpace Security Team的卓越贡献。您的专业知识和在道德黑客及网络安全工具开发方面的创新能力，给我们留下了深刻印象。

鉴于您的成就，我们诚挚邀请您参加北京网络安全大会2025，并在大会上分享您的见解和经验。大会将于2025年在北京举行，主题为“AI与网络安全的前沿趋势”。作为一位在网络安全领域的领先专家，我们相信您的演讲将为与会者提供极大的价值，同时也将进一步提升大会的学术深度和行业影响力。

如果您对这次邀请感兴趣，请点击以下链接了解更多信息并提交您的演讲提案：[127.0.0.1:8899](#)。我们将在截止日期前期待您的回复。

作为演讲嘉宾，您将获得免费入场、VIP交流活动参与资格以及其他专属福利。我们期待您的参与，并希望能在大会上与您见面。

此致，

[姓名]

[职位]

北京网络安全大会2025组织委员会

[联系信息]

通过AI的Deep Search / Deep Research功能绘制用户画像，再基于用户画像信息生成具有定制性的钓鱼邮件内容。

武器化赋能场景（三）MCP与模型驱动的自动化钓鱼

基于本地QwQ 32B模型 + MCP (Swaks) 服务进行联动，对钓鱼邮件内容进行样式修饰，再伪造邮件信息插入恶意钓鱼链接发送至目标用户，实现钓鱼目的。



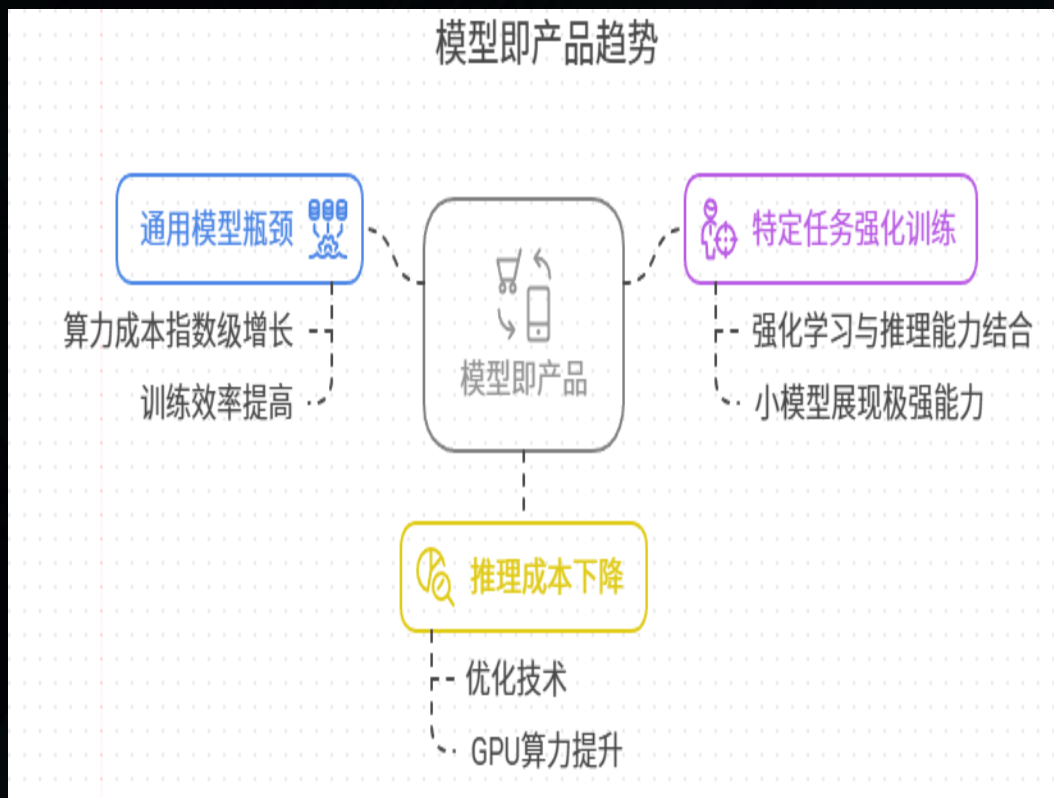
3：模型既产品既Agents---原生赋能场景

模型即产品

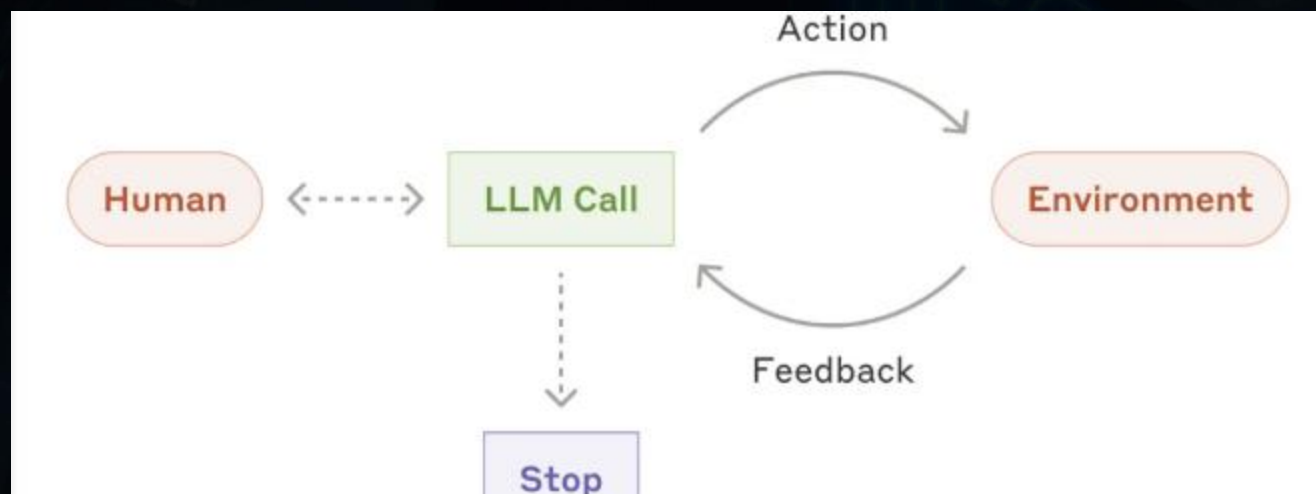
理想的智能体应能自主决定任务的具体实现过程和工具使用，而非被人为设计好的工作流程所限制

代表应用产品：DeepResearch与Claude Sonnet 3.7 及强大的模型基座

核心在于高度专业化，经过特定任务强化训练的模型能够自主完成特定任务

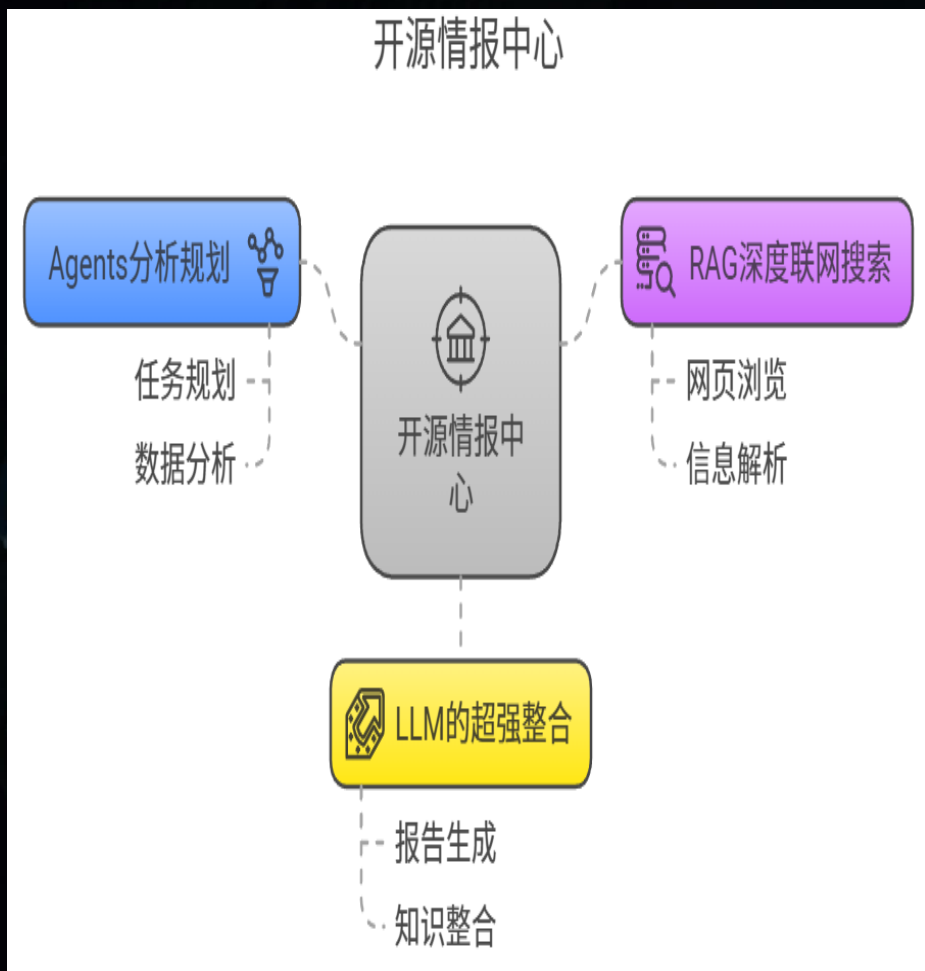


那如何应用赋能？



DeepResearch驱动的开源情报与画像制作

深度搜索本质：在内部完成搜索,浏览，解析并整合大量网页信息，生成研究报告
Agents分析规划+RAG深度联网搜索+ LLM的超强整合=开源情报中心



VII. 用户画像综合

A. 核心技术身份

EvilChen (gh0stkey) 是一位技术能力扎实的安全研究员，高度关注技术的实际应用，尤其在 Web 应用安全和相关工具开发方面表现突出。他展现了攻击性（红队思维、漏洞发现、模糊测试）和建设性（工具开发、知识分享）能力的结合。从其开发的 HaE 和 CaA 工具可以看出，他重视安全测试工作流的效率和自动化。通过在二进制分析/逆向工程领域的结构化学习，也显示了他对掌握底层基础知识的投入。

B. 社区角色

他是中国网络安全社区的活跃贡献者。以开发流行的开源安全工具（特别是 HaE）而闻名，并通过技术博客和资源仓库积极分享知识。他参与漏洞披露平台，并且是开发者和研究者网络的一员（通过 OverSpace 团队、与 Ochence 的合作以及博客链接可见）。

C. 自述兴趣

在其公开资料中明确列出的兴趣是“黑客、编程、音乐”¹。“黑客”和“编程”的兴趣与其公开的技术活动和产出高度吻合。“音乐”作为一项个人兴趣被提及，但在现有公开信息中未发现更多相关细节。

D. 潜在更广泛兴趣（需谨慎对待）

如果将那些关联性不确定的别名考虑在内，该个体可能还对游戏（《荒野大镖客2》⁶）、汽车（本田 S2000）或家庭实验室技术（Unraid 讨论¹⁹）感兴趣。然而，必须再次强调，这部分推断基于低置信度的别名匹配，应被视为高度推测性的信息。

VIII. 结论

基于对公开来源情报的系统性收集与分析，可以勾勒出网络安全个体 EvilChen (gh0stkey) 的用户画像。该个体是一位来自中国的安全研究员，隶属于 OverSpace Security Team。

其核心技术优势在于 Web 应用安全领域，尤其擅长开发实用工具以提升测试效率，代表作为广受欢迎的 Burp Suite 扩展 HaE 和 CaA。他还展现了在二进制分析/逆向工程方面的学习投入，并通过漏洞研究与披露活动证明了实战能力。主要使用的编程语言为 Java。

EvilChen (gh0stkey) 通过开发开源工具、维护技术博客和资源库，在社区中扮演着重要的知识贡献者角色。他与包括 Ochence 在内的其他开发者存在合作关系，并活跃于中国的网络安全社区。其活动时间线显示了自 2017 年以来在该领域的持续投入和发展。

本报告的所有结论均严格依据公开可获取的信息得出，并已尽力区分客观事实与分析推断。综合来看，EvilChen (gh0stkey) 是一位在技术实践和社区贡献方面均有建树的安全专业人士，尤其在 Burp Suite 用户群体和中国安全技术圈内具有显著的影响力。

供应链分析？ 舆情/威胁情报查询？ 全网相似漏洞的查询？

想法灵活， 涉及信息整合分析的 都适合DeepResearch用来赋能

梅赛德斯-奔驰第三方风险评估与间接攻击路径分析报告

1. 执行摘要

本报告旨在通过分析来自暗网、安全社区、代码库和新闻等非结构化信息源，识别并预测通过第三方供应商和服务提供商（“第三方”）针对梅赛德斯-奔驰（“主要目标”）的潜在间接攻击路径和脆弱点。分析显示，梅赛德斯-奔驰高度依赖其技术和供应链伙伴，这些伙伴关系虽然推动了创新，但也引入了显著的网络安全风险。

关键发现包括：

- 高风险第三方：** 主要云服务提供商（AWS、Microsoft Azure、Google Cloud）、核心软件供应商（SAP）、关键汽车技术合作伙伴（Nvidia、Bosch、Continental）因其与梅赛德斯-奔驰核心业务、IT基础设施、软件开发和敏感数据处理的深度整合而构成最高风险。
- 主要攻击向量：** 凭证泄露（通过钓鱼或暗网交易获取）、云环境账户接管（ATO）（利用钓鱼、MFA绕过等手段）、关键软件漏洞利用（如SAP代码注入、Nvidia容器工具包逃逸）、以及针对特定硬件/软件（如Bosch生产工具）的攻击是主要的间接攻击途径。
- 新兴威胁：** 针对云存储的勒索软件（如利用AWS SSE-C加密）、利用云服务未监控区域进行恶意活动、以及针对AI开发基础设施的攻击是值得关注的新兴威胁。
- 潜在影响：** 成功的间接攻击可能导致梅赛德斯-奔驰的敏感数据泄露、核心业务中断（如生产线停工、财务系统瘫痪）、车辆功能受损（如MBUX、ADAS）、知识产权被盗以及声誉受损。

报告基于证据提出了具体的攻击假设，并提供了可操作的建议，旨在帮助梅赛德斯-奔驰加强其第三方风险管理（TPRM）计划，提升对间接网络威胁的预警和防御能力。

2. 引言

2.1 背景与范围

梅赛德斯-奔驰在全球汽车行业以其创新和品质著称，其运营高度依赖于一个庞大而复杂的第三方生态系统，包括技术合作伙伴、软件供应商、云服务提供商和零部件制造商。当前的网络威胁环境日益严峻，攻击者越来越倾向于将供应链和第三方服务提供商作为攻击入口，利用其信任关系或技术连接，间接渗透主要目标。本报告聚焦于识别和评估这些通过第三方针对梅赛德斯-奔驰的潜在、隐藏的间接攻击路径和脆弱点。分析范围严格限定于从公开可用的非结构化信息源（如暗网论坛、安全社区博客、代码库、新闻稿、合作公告等）收集的情报。

目标第三方/系统	关键漏洞/弱点利用	证据 (Snippet IDs)	潜在攻击者TTPs	对梅赛德斯-奔驰的潜在影响
AWS (托管SAP等)	泄露的凭证, S3配置错误, SSE-C勒索软件, 未监控区域利用		凭证盗窃, 云配置扫描, SSE-C勒索, 规避检测	SAP系统瘫痪, 核心业务中断, 数据泄露/丢失, 财务损失
Microsoft Azure (MBUX AI, 生产)	ATO (钓鱼+MFA操纵), Azure AI服务漏洞 (CVE-2025-21415), 其他服务漏洞		钓鱼, MFA绕过/注册, 漏洞利用 (Auth Bypass), 凭证盗窃	MBUX功能异常/数据泄露, 生产流程受影响/数据泄露, 内部钓鱼/欺诈
Google Cloud (MBUX AI, 地图)	泄露的凭证, 云账户攻击, 利用可见性差距		凭证盗窃, 钓鱼, 利用未监控资源	MBUX导航/搜索功能异常, 用户体验下降, 用户交互数据泄露
SAP (ERP on AWS)	代码注入 (CVE-2025-27429), 目录遍历 (CVE-2017-12637), RFC凭证检索, 其他漏洞		漏洞利用 (代码注入, 目录遍历), 补丁管理利用	核心业务系统完全受控, 财务/客户/供应链数据泄露或篡改, 业务中断, 勒索软件
Nvidia (ADAS计算平台)	Container Toolkit容器逃逸, GPU驱动/vGPU漏洞 (代码执行风险)		漏洞利用 (容器逃逸, 内存损坏), 凭证盗窃 (参考)	ADAS模型/算法被盗, ADAS软件供应链投毒, 车辆计算单元受控风险, 研发中断
Bosch (ADAS研发, 生产工具)	Rexroth Web界面漏洞 (系统接管), Nutrunner漏洞 (勒索/篡改)		漏洞利用 (Web RCE, 固件漏洞), 勒索软件部署, OT网络渗透	ADAS研发数据泄露, 生产线停工, 车辆质量/安全问题, 勒索
Continental (零部件)	勒索软件攻击, 产品/系统漏洞		勒索软件, 漏洞利用, 网络入侵	供应链中断, 商业信息泄露, 可能作为跳板
车联网平台伙伴 (API)	API漏洞 (认证/授权/注入)		API模糊测试, 注入攻击, 认证绕过	车辆数据泄露, 车主隐私泄露, 可能的车辆控制风险 (取决于API功能)

言出法随，两分钟自动建构钓鱼页面

Claude Sonnet 3.7 机制：模拟人脑的快慢思考，自我反思任务链条逻辑，并逐步分析解决问题
prompt：给我一个与图片高度逼真的网站页面+提供对应页面照片

真博客网页

Ai仿造网页

使用 Claude

了解如何开始使用Anthropic API和Claude。

帮我开始使用提示框存...

浏览文档 >

开始使用工具和指南



开始使用

几分钟内完成首次API调用。



API参考

使用我们的API和SDK进行集成和扩展。



Anthropic控制台

直接在浏览器中创建和测试强大的提示。



Anthropic课程

探索Anthropic的教育课程和项目。



Anthropic手册

查看可复制的代码示例和实现。



Anthropic快速入门

使用我们的API构建的可部署应用程序。

使用 Claude

了解如何开始使用Anthropic API和Claude。

帮我开始使用搜索框存...

浏览文档 >

开始使用工具和指南



开始使用

几分钟内完成首次API调用。



API参考

使用我们的API和SDK进行集成和扩展。



Anthropic控制台

直接在浏览器中创建和测试强大的提示。



Anthropic课程

探索Anthropic的教育课程和项目。



Anthropic手册

查看可复制的代码示例和实现。



Anthropic快速入门

使用我们的API构建的可部署应用程序。

多模态驱动的Deep Fake 赋能社工

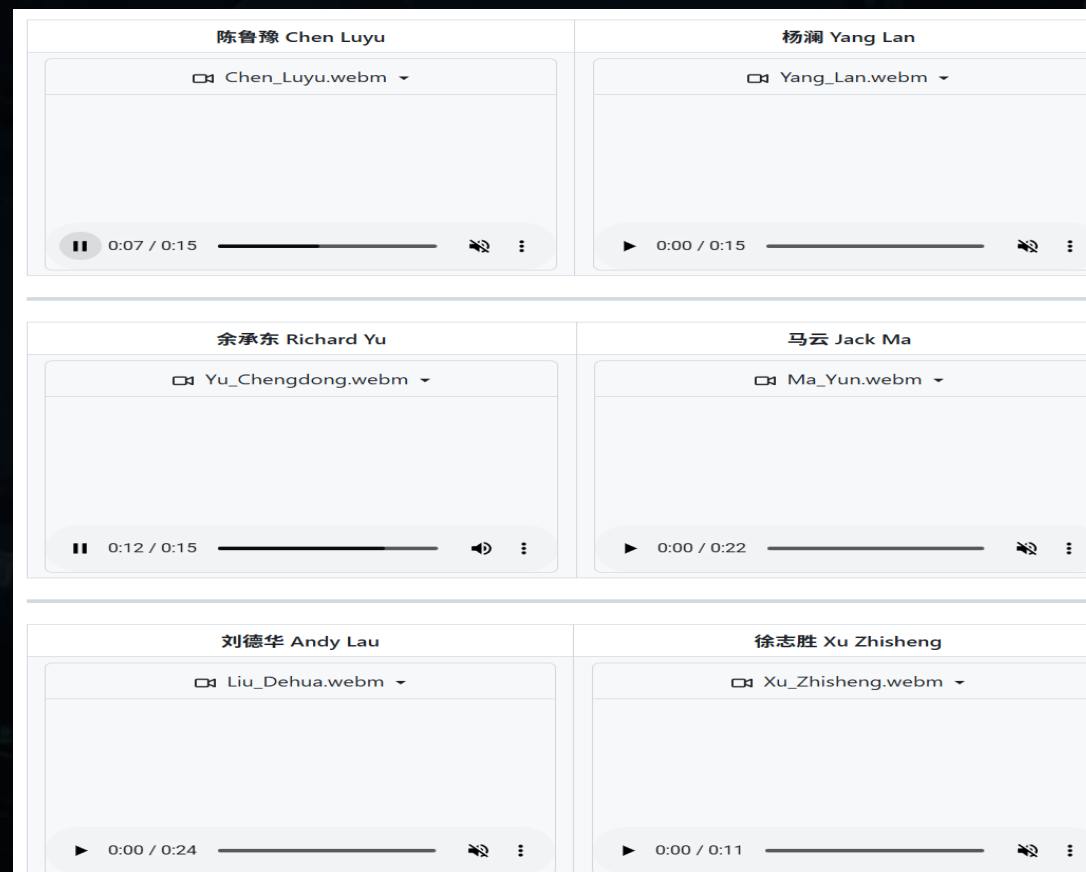
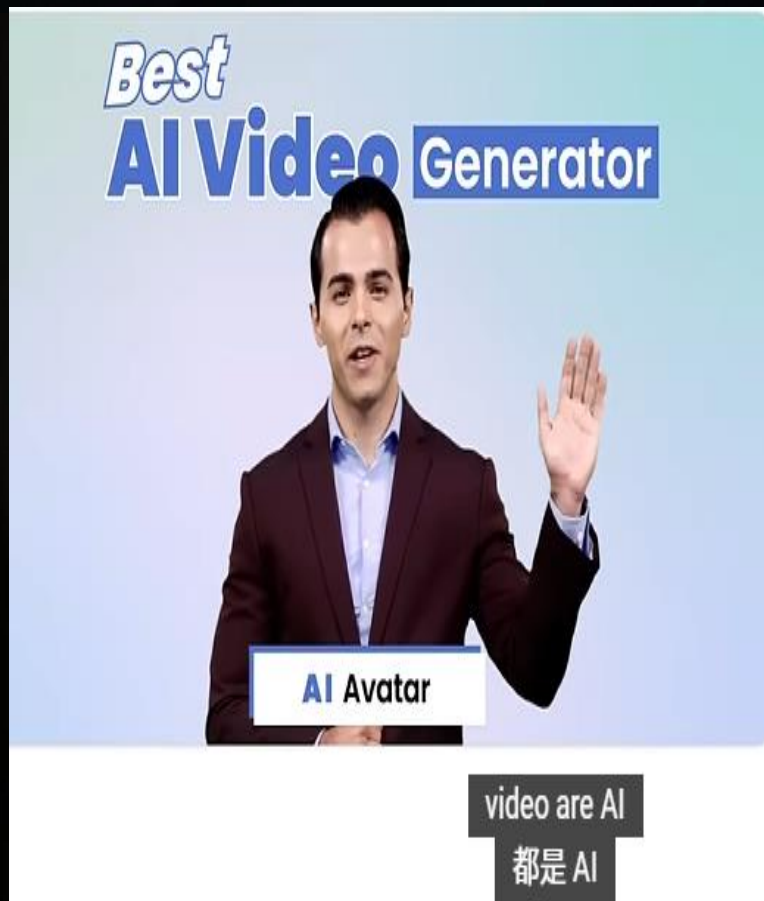
图像Ai: ChatGPT4o/既梦

语言克隆: Spark-TTS

视频制作: Deepbrain AI

内容创作: Cluade

作用在那? 很多需要鉴别身份的地方并不严格, 是否可成为芸芸众生任一职业的一员, 找寻新的漏洞面?



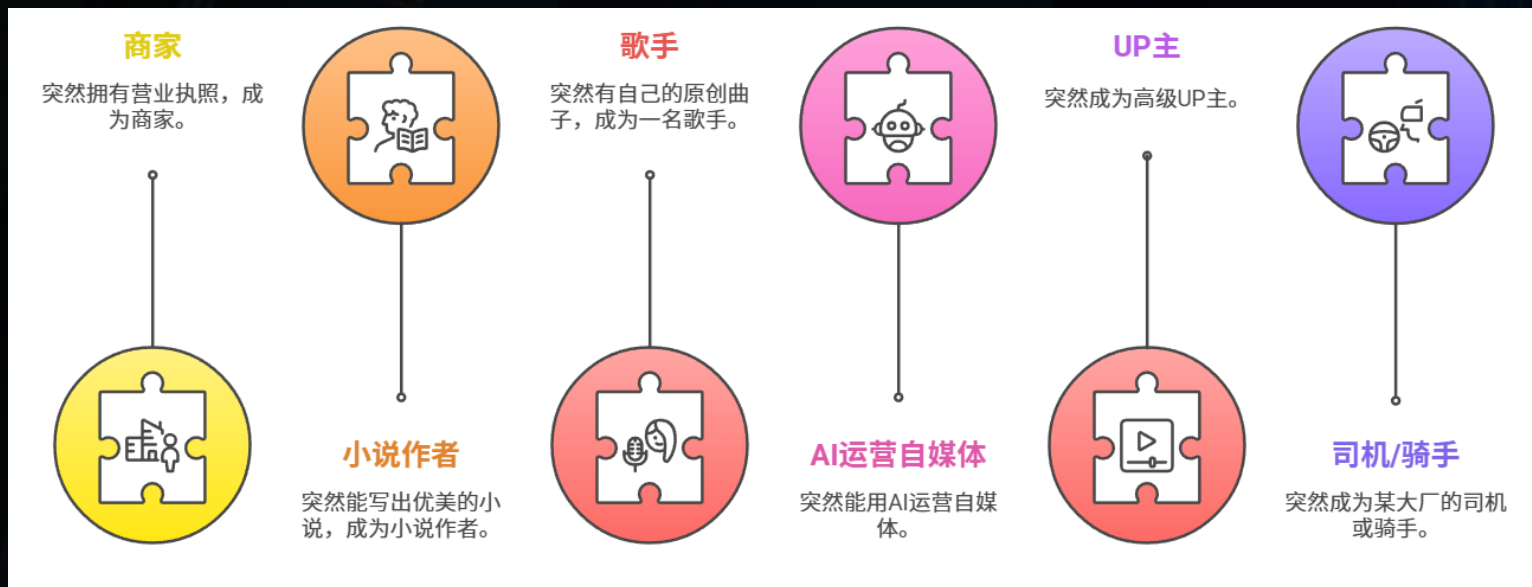
思维不设限，放开想象力

我们是否能够突然拿到某种特殊账户权限，恰好发现特殊的攻击面？

突然拥有营业执照成为商家

或者突然能创造出优质视频，成为高级UP主

或者突然有自己的原创曲子 成为一名歌手

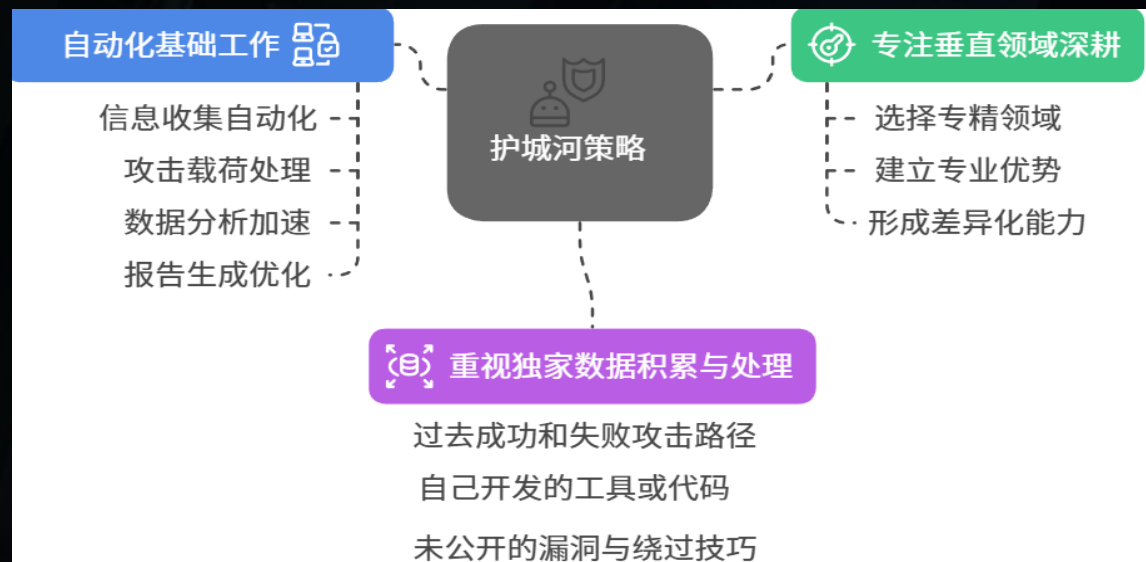


4: Ai大模型热潮下自我反共识观点

反共识思考 (1) ----如何差异化与模型竞争

模型发展很快，基于它做的应用，很容易被新功能降维打击，如4o更新对于设计业，Cursor Claude与初级程序员不能光想着“套壳”大模型，得与模型建立差异化策略，才可以不能降维打击淘汰

- 1.垂直领域深耕. 如 专精专细 技术壁垒高的领域 逆向 高级渗透 安全架构设计 应急响应等等
同样专注垂直领域模型能识别通用找不到的漏洞点
2. 注重私有数据的积累，清洗与整理甚至是合成，**独家数据是王牌**，用别人没有的独家数据
能生成更有效更隐蔽,贴合实际的方案，是公开数据训练的大模型无法做到的点
- 3.尝试工程实践去让Ai提效那些“不炫酷”但**耗时的基础活儿**，让自己专注更高维度的事情



反共识思考 (2) --怎么更好建立护城河?

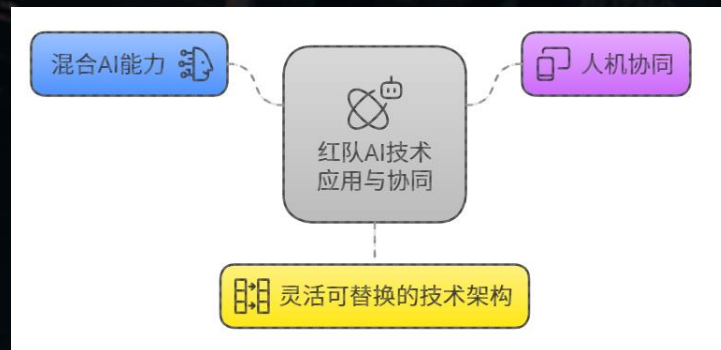
1. 模型非万能，考虑混合运用，传统+模型结合，（比如正则+LLM，模型搜集—扫描器扫描—模型给出建议，IDA代码分析—模型辅助利用思路等等）

2. 不要依赖AI全自动化，人机协同（审查模型的逻辑，关键地方还是得有人把关 协作）

3. 特别重要：做好架构设计和技术选型,技术上要能灵活变通参考乐高积木（别绑死一个模型，随时能换能调）

- 设计AI赋能工具链时，采用模块化架构，不同的功能（如侦察模块、漏洞扫描模块、Payload生成模块）独立开发
- 在调用大模型时,定义抽象层或接口,在你的应用代码和大模型之间建立一个标准化的中间层，让你的核心功能通过中间层与大模型交互，而不是被具体的大模型给绑定死，导致重换时 费时费力
- 通过配置文件来指定当前使用哪个大模型或哪个版本的工具，想换则换

当有新的、更好的大模型出现时，或者模型新技术需要添加时候
只需要更新对应的模块或修改配置，而不用重写整个工具链



致谢与交流

感谢好友Key师傅对本议题Ai赋能武器化的独家支持
另外感谢林晨，札克利师傅的指点



[_gh0stkey \(EvilChen\)](#)

欢迎技术交流->



谢谢



IFS